

CYBERSECURITY ASSESSMENT REPORT

Week 1 : Vulnerability Testing & Audit

Intern Name	BUSHRA JABEEN	Intern ID	DHC-587
Application	OWASP ZAP		
Environment	Localhost:8080		
Date	May - 2026		

1. Executive Summary

This report details the findings of a security assessment performed on the Node.js backend application running locally on port 8080. The assessment utilized **OWASP ZAP** for automated vulnerability scanning to discover security loopholes, missing defense mechanisms, and potential configurations that could expose the application to cyber threats.

The screenshot displays the OWASP ZAP (Zed Attack Proxy) interface during an automated scan. The main window is titled "Automated Scan" and includes the ZAP logo. It provides instructions for launching a scan and a warning about unauthorized attacks. The configuration section shows the URL to attack as "http://localhost:8080", the scan policy as "Dev Standard", and the use of traditional and ajax spiders. The progress bar indicates the attack is complete. The bottom panel shows a list of alerts, including "CSP: Failure to Define Directive with No Fallback (Systemic)", "Authentication Request Identified (4)", "Information Disclosure - Sensitive Information in URL (Systemic)", and "User Controllable HTML Element Attribute (Potential XSS) (1,515)". The status bar at the bottom shows the current status and the main proxy is set to localhost:8080.

File Edit View Analyse Report Tools Import Export Online Help

Untitled Session - ZAP 2.17.0

Standard Mode

Sites +

Contexts

Default Context

Sites

Quick Start Request Response Requester +

Automated Scan

This screen allows you to launch an automated scan against an application - just enter its URL below and press 'Attack'.
Please be aware that you should only attack applications that you have been specifically given permission to test.

URL to attack: http://localhost:8080 Select...

Scan Policy: Dev Standard

Use traditional spider: ☒

Use ajax spider: If Modern with Firefox

Attack Stop

Progress: Attack complete - see the Alerts tab for details of any issues found

History Search Alerts Output Spider Active Scan +

Alerts (4)

- CSP: Failure to Define Directive with No Fallback (Systemic)
- Authentication Request Identified (4)
- Information Disclosure - Sensitive Information in URL (Systemic)
- User Controllable HTML Element Attribute (Potential XSS) (1,515)

Full details of any selected alert will be displayed here.

You can manually add alerts by right clicking on the relevant line in the history and selecting 'Add alert'.
You can also edit existing alerts by double clicking on them.

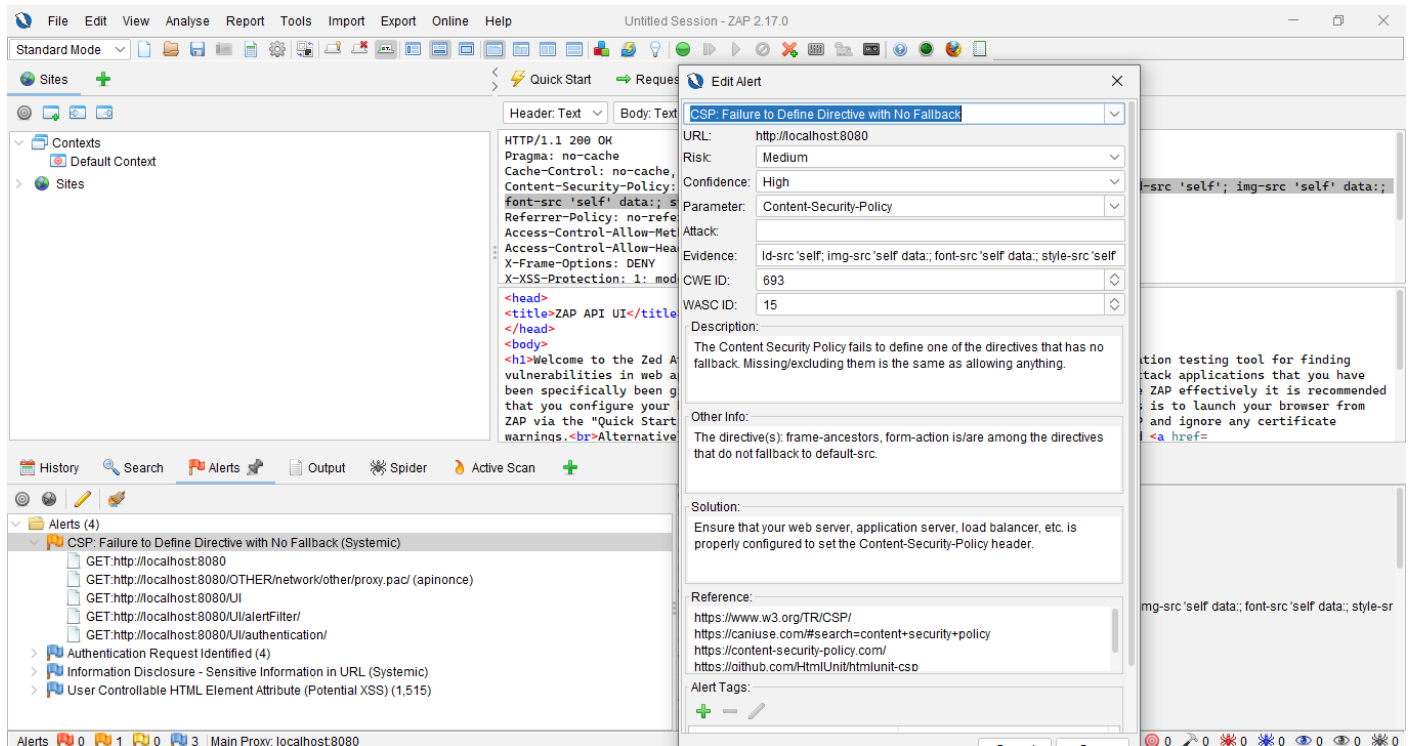
Alerts 0 1 0 3 Main Proxy: localhost:8080

Current Status 0 0 0 0 0 0 0 0 0 0 0 0

2. Automated Scanning Phase

OWASP ZAP was configured to perform an Automated Scan against the target environment (<http://localhost:8080>). ZAP successfully mapped the application's attack surface via traditional and AJAX spidering, followed by an Active Scan phase that simulated real-world attack vectors.

The automated scan concluded successfully with "**Attack complete**" and flagged potential vulnerabilities classified by risk levels.



2. Key Findings & Vulnerability Breakdown:

- CSP: Failure to Define Directive with No Fallback (Medium Risk)**
 - Description:** The Content Security Policy (CSP) header is either missing entirely or fails to define strict fallback directives (like `default-src`).
 - Impact:** Without a strict CSP, the application is highly vulnerable to Cross-Site Scripting (XSS) and data injection attacks, allowing malicious scripts to execute in the user's browser context.
 - CWE ID:** 693 (Insufficient Trust Management)
- User Controllable HTML Element Attribute - Potential XSS (Low Risk)**
 - Description:** ZAP detected that certain input parameters controlled by the user are reflected back into HTML attributes without adequate sanitization or contextual encoding.
 - Impact:** An attacker could input malicious payloads that manipulate HTML attributes, leading to client-side script execution (XSS).
- Information Disclosure - Sensitive Information in URL (Low Risk)**
 - Description:** The application appears to pass parameters or identifiers through the URL string that could leak sensitive transactional or contextual data.
 - Impact:** Sensitive parameters inside URLs can be captured in server logs, browser history, or referrer headers, exposing internal architecture details to attackers.
- Authentication Request Identified (Informational)**
 - Description:** ZAP successfully identified the authentication endpoints (such as `/api/auth/signin`), mapping out where the application handles session creation and credential verification.